

มหาวิทยาลัยธรรมศาสตร์

สาขาวิชาวิทยาการคอมพิวเตอร์

คณะวิทยาศาสตร์และเทคโนโลยี

รายวิชา: cs234

ภาคการศึกษา: 2/2568

Security Labs: Web Security - SQL Injection Attack

คะแนนเต็ม: 100 คะแนน

นักศึกษาโปรดทราบ

1. การบ้านนี้เป็นงานกลุ่ม

- ทำงาน (task) ตามข้อกำหนดการบ้านในเอกสารฉบับนี้ ให้ครบถ้วน
- การไม่ปฏิบัติตามคำสั่งต่าง ๆ ที่กำหนดไว้ด้านล่าง เช่นการตั้งชื่อแฟ้มข้อมูลตามรูปแบบที่กำหนด อาจมีผลให้การบ้านชิ้นนี้ของนักศึกษาไม่ได้รับการตรวจ
- การลอกการบ้าน การทำซ้ำโปรแกรม ถือเป็นการกระทำผิดวินัยนักศึกษาอย่างร้ายแรง หากมีหลักฐานที่แน่ชัด
ผู้สอนมีสิทธิดำเนินการลงโทษนักศึกษาตามระเบียบข้อบังคับเกี่ยวกับการกระทำผิดวินัยนักศึกษาได้
- ภายหลังจากทำสำเร็จครบทุกงาน (task) ตามข้อกำหนดในเอกสารฉบับนี้แล้วเสร็จ
ให้จัดเตรียมไฟล์รายงาน ในรูปแบบ pdf ตั้งชื่อตามข้อกำหนด คือ cs234_68-2_SecurityLab03-SQL-Injection--Gxx.pdf
เมื่อ Gxx คือ รหัสกลุ่มการบ้านที่ได้รับจัดสรรจากอาจารย์
- ส่งไฟล์รายงานในกล่องรับการบ้านที่จัดเตรียมไว้บนเว็บไซต์รายวิชา ภายในเวลาที่กำหนด เท่านั้น
- ทรัพยากรและรายการงาน (task) ในการบ้านชิ้นนี้อ้างอิงจาก [SEED Labs 2.0 – SQL Injection Attack](#)

สิ่งที่ต้องส่ง

ผู้แทนกลุ่มส่งรายงานที่มีผลลัพธ์จากการทำงาน Task 2 - Task 4 (แต่ละ Task อาจมีงานย่อย) สำหรับแต่ละ Task รายงานของนักศึกษาต้องตอบคำถาม อภิปรายเหตุผลประกอบคำตอบของนักศึกษา และแสดงภาพหน้าจอซึ่งมีผลลัพธ์ของการโจมตีแบบ SQL Injection ที่ได้ทดลองปฏิบัติในแต่ละ Task ด้วย เพื่อแสดงให้เห็นถึงความเข้าใจของนักศึกษา

หมายเหตุ สำหรับ Task 1: Get Familiar with SQL Statements

นักศึกษาดำเนินการตาม lab instructions เพื่อทำความเข้าใจเกี่ยวกับการใช้งาน SQL Statements ไม่มีงานต้องส่งสำหรับ Task 1 นี้

คำอธิบายการบ้าน

ในการบ้านนี้ นักศึกษาจะได้ทบทวนการโจมตีรูปแบบ SQL Injection attack ซึ่งอาศัยช่องโหว่ต่าง ๆ ของเว็บแอปพลิเคชันที่ได้อภิปรายในห้องเรียน

ผ่านการปฏิบัติจริงภายใต้สภาพแวดล้อมที่จำลองขึ้นภายในเครื่องเสมือน (virtual machine - VM) จำนวน 1 เครื่อง พร้อมทั้งเรียนรู้แนวทางการป้องกันการโจมตีแบบ SQL Injection attack ด้วย

เครื่องเสมือน ที่จัดเตรียมไว้ติดตั้งระบบปฏิบัติการ Ubuntu 20.04 (pre-built Ubuntu VM image) มีโปรแกรมเว็บเซิร์ฟเวอร์ (Apache) เว็บแอปพลิเคชัน (Elgg) และ ฐานข้อมูล (MySQL) รันอยู่

- **เว็บเซิร์ฟเวอร์และเว็บแอปพลิเคชัน** ถูกสร้างเป็นอิมเมจ (image) รันในลักษณะของคอนเทนเนอร์ (container) หนึ่งเครื่อง และ
- **ฐานข้อมูล** (MySQL database) ถูกสร้างเป็นอิมเมจ รันในลักษณะของคอนเทนเนอร์อยู่อีกหนึ่งเครื่อง

ดังนั้น นักศึกษาควรมีความเข้าใจเบื้องต้นเกี่ยวกับการทำงานของ **ด็อกเกอร์ (docker)** และ **คอนเทนเนอร์** โดยศึกษาเอกสารคู่มือได้ตามลิงก์นี้ [Docker manual](#)

ฐานข้อมูล MySQL database

ในแล็บนี้ ฐานข้อมูลมายเอสคิวแอล (MySQL Database) อยู่ภายในคอนเทนเนอร์ ชื่อ mysql-10.9.0.6 สำหรับแล็บนี้ เราต้องการเก็บข้อมูลภายใน MySQL database ไว้ แม้ว่าคอนเทนเนอร์จะถูกทำลายไปแล้ว ดังนั้น จะมีการสร้างและผูกโฟลเดอร์ mysql_data ภายในเครื่อง VM กับโฟลเดอร์ /var/lib/mysql ภายในคอนเทนเนอร์ MySQL เพื่อจัดเก็บข้อมูลของฐานข้อมูลไว้ โฟลเดอร์ mysql_data ภายในเครื่อง VM จะไม่ถูกทำลาย แม้ว่าคอนเทนเนอร์จะถูกทำลายไปแล้ว ดังนั้น หากเราต้องการเริ่มต้นฐานข้อมูลใหม่เลย (clean database) ต้องลบโฟลเดอร์ mysql_data บนเครื่อง VM ออกไป ด้วยคำสั่ง `$ sudo rm -f mysql_data`

เว็บแอปพลิเคชัน (About Web Application)

เว็บแอปพลิเคชันในแล็บนี้เป็นแอปพลิเคชันแบบง่ายสำหรับการจัดการข้อมูลพนักงาน (simple employee management application)

ผู้ใช้ของแอปพลิเคชันมี 2 บทบาท ได้แก่ Administrator และ Employee

- Employee: สามารถเรียกดู (view) และ อัปเดต (update) ข้อมูลของตนเองได้
- Administrator: มีสิทธิพิเศษสามารถจัดการข้อมูลของพนักงานแต่ละคนได้

ข้อมูลของพนักงานทุกคนในฐานข้อมูลถูกจัดแสดงในตาราง Table 1.

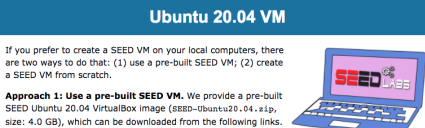
Table 1: Database									
Name	Employee ID	Password	Salary	Birthday	SSN	Nickname	Email	Address	Phone#
Admin	99999	seedadmin	400000	3/5	43254314				
Alice	10000	seedalice	20000	9/20	10211002				
Boby	20000	seedboby	50000	4/20	10213352				
Ryan	30000	seedryan	90000	4/10	32193525				
Samy	40000	seedsamy	40000	1/11	32111111				
Ted	50000	seedted	110000	11/3	24343244				

ในปฏิบัติการนี้ นักศึกษาจะได้ทดลองสร้างการโจมตีแบบ **SQL Injection** กับ **โปรแกรมเว็บแอปพลิเคชันแบบง่ายที่ได้จัดทำขึ้นเพื่อใช้งานในแล็บนี้**

การโจมตีจะมีทั้งแบบใช้งาน **SELECT statement** และ **UPDATE statement** รวมทั้งได้ศึกษาการใช้งาน **PREPARED statement** ในการป้องกันการโจมตีแบบ **SQL Injection** ด้วย

ข้อกำหนดการบ้าน นักศึกษาทำตามขั้นตอนต่อไปนี้

1. ดาวนโหลดและติดตั้งเครื่องเสมือนที่ได้มีการจัดเตรียมไว้สำหรับจำลองสภาพแวดล้อมของการบ้านนี้

a. ดาวนโหลดและติดตั้ง VirtualBox 6.1 โดยเลือกไฟล์ที่จะดาวนโหลดให้สอดคล้องกับระบบปฏิบัติการของเครื่องโฮสต์ (host machine) หมายเหตุ The SEED VM has been tested on Version 6.1.16.	 VirtualBox 6.1.18 platform packages - Windows hosts - OS X hosts - Linux distributions - Solaris hosts - Solaris 11 IPS hosts The binaries are released under the terms of the GPL version 2.
b. ดาวนโหลดเครื่องเสมือน SEED VM (SEED-Ubuntu20.04.zip) จากเว็บไซต์ SEED LAB จากนั้นทำการตั้งค่าเครื่องโฮสต์ เครื่องเสมือน และโปรแกรม VirtualBox เพื่อใช้งานเครื่องเสมือน SEED VM ตามขั้นตอนและคำแนะนำในเว็บไซต์นี้ https://github.com/seed-labs/seed-labs/blob/master/manuals/vm/seedvm-manual.md นักศึกษาสามารถคลิกเพื่อดาวนโหลดไฟล์สำหรับเซตอัปแล็บ (Lab Setup file) ได้ที่นี่: Labsetup.zip	 Ubuntu 20.04 VM If you prefer to create a SEED VM on your local computers, there are two ways to do that: (1) use a pre-built SEED VM; (2) create a SEED VM from scratch. Approach 1: Use a pre-built SEED VM. We provide a pre-built SEED Ubuntu 20.04 VirtualBox image (SEED-Ubuntu20.04.zip, size: 4.0 GB), which can be downloaded from the following links. - Google Drive - DigitalOcean - MD5 value: f3d2227c9221926567940064a0a1287 - VM Manual: follow this manual to install the VM on your computer Approach 2: Build a SEED VM from scratch. The procedure to build the SEED VM used in Approach 1 is fully documented, and the code is open source. If you want to build your own SEED Ubuntu VM from scratch, you can use the following manual. - How to build a SEED VM from scratch
c. อ่านและปฏิบัติตามหัวข้อ 2. Lab Environment Setup ในไฟล์ Lab Sheet เพื่อตั้งค่าและรันคอนเทนเนอร์ ภายในเครื่องเสมือน ซึ่งเป็นสภาพแวดล้อมของปฏิบัติการนี้ หรือดูไคต์ไลน์แบบย่อในการตั้งค่าสภาพแวดล้อมของปฏิบัติการนี้ ที่นี่ นักศึกษาที่ไม่คุ้นเคยกับการใช้งานคอนเทนเนอร์ ต้องอ่านคู่มือความเข้าใจเบื้องต้นเกี่ยวกับการทำงานของ ด็อกเกอร์ (docker) และ คอนเทนเนอร์	

ตามลิงก์นี้ [Docker manual](#)

2. ทำ Tasks ตามข้อกำหนดต่อไปนี้
 - a. หัวข้อ **3. Lab Tasks** ในไฟล์ [Lab Sheet](#)
 - i. หัวข้อ **3.1 Task 1: Get Familiar with SQL Statements**
ให้ดำเนินการตาม lab instructions เพื่อทำความเข้าใจกับการใช้งาน SQL Statements
ไม่มีงานต้องส่งสำหรับ Task 1 นี้
 - ii. หัวข้อ **3.2 - 3.3 (Task2 - Task3)** เป็น tasks ซึ่งจำลองการโจมตีแบบ SQL Injection
รูปแบบต่าง ๆ
 - iii. หัวข้อ **3.4. Task 4: Countermeasure SQL Injection Attacks using Prepared Statement**
อภิปรายแนวทางการป้องกันการโจมตีรูปแบบ SQL Injection โดยใช้ Prepared Statement
3. เขียนรายงานอภิปรายผลลัพธ์ของ Task 2 - Task 4 พร้อมข้อมูลประกอบการอภิปรายอย่างเหมาะสม
(ดูรายละเอียดที่หัวข้อ 'สิ่งที่ต้องจัดส่ง')